

Save Your Cloud: DoS on VMs in OpenNebula 4.6.1

Save Your Cloud: DoS on VMs in OpenNebula 4.6.1 - Author not stated, web-in-security.blogspot.com.

- Published: date not stated
- Original: <<https://web-in-security.blogspot.com/2018/07/save-your-cloud-dos-on-vms-in.html>>
- Preserved from: <https://web-in-security.blogspot.com/2018/07/save-your-cloud-dos-on-vms-in.html> (live) on 2026-08-09
- Licence: unknown

Rights remain with the original author and publisher. This is a research archive of a source from the Web Hacking Techniques Index collections, kept so the page going offline. To read the original, follow the link above.

Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

This is a post about an old vulnerability that I finally found the time to blog about. It dates back to 2014, but from a technical point of view it is nevertheless interesting: An XML parser that tries to fix structural errors in a document caused a DoS problem.

All previous posts of [this series](#) focused on XSS. This time, we present a vulnerability which is connected another Cloud Management Platform: [OpenNebula](#). This Infrastructure-as-a-Service platform started as a research project in 2005. It is [used by information technology companies](#) like IBM, Dell and Akamai as well as academic institutions and the European Space Administrations (ESA). By relying on standard Linux tools as far as possible, OpenNebula reaches a high level of customizability and flexibility in hypervisors, storage systems, and network infrastructures. OpenNebula is distributed using the Apache-2 license.

OpenNebula offers a broad variety of interfaces to control a cloud. This post focuses on Sunstone, OpenNebula's web interface (see Figure 1).

| ! | | | Figure 1: OpenNebula's Sunstone Interface displaying a VM's control interface | |

Before OpenNebula 4.6.2, Sunstone had no [Cross-Site Request Forgery \(CSRF\)](#) protection. This is a severe problem. Consider an attacker who lures a victim into clicking on a malicious link while being logged in at a private cloud. This enables the attacker to send arbitrary requests to the private cloud through the victims browser. However, we could find other bugs in OpenNebula that allowed us to perform much more sophisticated attacks.

Denial-of-Service on OpenNebula-VM

At its backend, OpenNebula manages VMs with XML documents. A sample for such an XML document looks like this:

```
<VM>
```

```
<ID>0</ID> <NAME>My VM</NAME> <PERMISSIONS>...</PERMISSIONS>  
<MEMORY>512</MEMORY> <CPU>1</CPU> ... </VM>
```

OpenNebula 4.6.1 contains a bug in the sanitization of input for these XML documents: Whenever a VM's name contains an opening XML tag (but no corresponding closing one), an XML generator at the backend automatically inserts the corresponding closing tag to ensure well-formedness of the resulting document. However, the generator outputs an XML document that does not comply with the XML schema OpenNebula expects. The listing below shows the structure that is created after renaming the VM to 'My <x> VM':

```
<VM>
```

```
<ID>0</ID> <NAME>My <x> VM</x> <PERMISSIONS>...</PERMISSIONS>  
<MEMORY>512</MEMORY> <CPU>1</CPU> ... </NAME> </VM>
```

The generator closes the <x> tag, but not the <NAME> tag. At the end of the document, the generator closes all opened tags including <NAME>.

OpenNebula saves the incorrectly generated XML document in a database. The next time the OpenNebula core retrieves information about that particular VM from the database the XML parser is mixed up and runs into an error because it only expects a string as name, not an XML tree. As a result, Sunstone cannot be used to control the VM anymore. The Denial-of-Service attack can only be reverted from the command line interface of OpenNebula.

This bug can be triggered by a CSRF-attack, which means that it is a valid attack against a private cloud: By luring a victim onto a maliciously crafted website while logged in into Sunstone, an attacker can make all the victim's VMs uncontrollable via Sunstone. A video of the attack can be seen [here](#):

This bug has been fixed in [OpenNebula 4.6.2](#).

This result is a collaborative work together with [Mario Heiderich](#). It has been published at [ACM CCS W 2015](#). The paper can be found [here](#).